

# Évaluation des risques : sonde de niveau d'eau NV-2, version 1.0

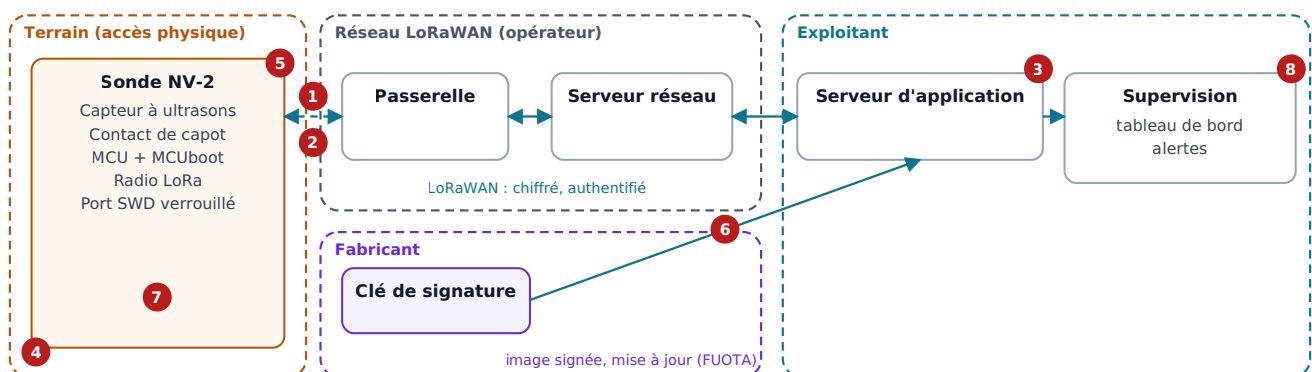
Exemple fictif, rédigé pour la série « CRA & Dev » afin d'illustrer l'article 13 du Cyber Resilience Act. Le produit, les choix et les cotations sont des exemples : ils ne remplacent pas l'analyse de votre propre produit.

## 1. Contexte

| Rubrique                         | Contenu                                                                                                                                                                                                                                                                                                                        |
|----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Usage prévu                      | Mesurer le niveau d'eau d'une citerne ou d'un réservoir public, en déduire le volume, l'envoyer toutes les heures par LoRaWAN, et alerter aussitôt sous un seuil bas ou au-dessus d'un seuil haut. La collectivité s'en sert pour planifier les remplissages et surveiller ses réserves d'eau pour la lutte contre l'incendie. |
| Usage raisonnablement prévisible | Seule surveillance d'une réserve incendie, sans contrôle visuel régulier ; détection de fuites ; données partagées avec les services de secours.                                                                                                                                                                               |
| Environnement                    | En extérieur, sur des sites isolés et souvent sans surveillance. Alimentée par pile. Réseau LoRaWAN public.                                                                                                                                                                                                                    |
| Actifs à protéger                | Intégrité et disponibilité des niveaux et des alertes, dont dépend la sécurité des personnes pour les réserves incendie ; seuils d'alerte ; intégrité du firmware ; clés LoRaWAN (clé racine propre à chaque appareil).                                                                                                        |
| Données traitées                 | Niveau, volume calculé, température, tension de la pile, état du capot. Aucune donnée personnelle.                                                                                                                                                                                                                             |
| Durée d'utilisation prévue       | 10 ans. Période d'assistance : 10 ans.                                                                                                                                                                                                                                                                                         |
| Interfaces                       | Radio LoRaWAN (mesures, alertes, configuration des seuils, mises à jour) ; port de débogage SWD, verrouillé en production ; contact d'ouverture du capot.                                                                                                                                                                      |

## 2. Schéma

Les numéros renvoient aux risques du tableau suivant.



## 3. Risques

Vraisemblance (V) et impact (I) : faible, moyen(ne), élevé(e).

| # | Menace : qui, par où                                                                   | V       | I      | Décision                  | Mesure ou justification                                                                                                                                                                                                                         |
|---|----------------------------------------------------------------------------------------|---------|--------|---------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 | Une trame falsifiée ou rejouée fait croire qu'une réserve vide est pleine              | faible  | élevé  | réduire                   | Trames authentifiées et compteurs de trames ; activation OTAA uniquement : chaque session a ses propres clés, une trame d'une session passée est rejetée ; la plateforme rejette les variations de niveau physiquement impossibles (point 2 f). |
| 2 | La sonde se tait (brouillage, pile vide, sonde détruite) et une baisse passe inaperçue | moyenne | élevé  | réduire                   | Message de vie toutes les heures ; alerte de pile basse un mois à l'avance. Hypothèse documentée dans la notice : la plateforme doit alerter après deux messages manqués (point 2 h).                                                           |
| 3 | Les seuils d'alerte sont modifiés à distance pour faire taire les alertes              | faible  | élevé  | réduire                   | Configuration acceptée seulement si elle est authentifiée ; seuils bornés ; chaque changement est renvoyé à la plateforme et journalisé (point 2 d, l).                                                                                         |
| 4 | Sur place, quelqu'un ouvre la sonde, la déplace ou obstrue le capteur                  | moyenne | moyen  | réduire                   | Le contact d'ouverture du capot envoie une alerte ; une mesure hors de la plage possible est signalée (point 2 d).                                                                                                                              |
| 5 | La clé racine est extraite d'une sonde volée                                           | moyenne | faible | réduire                   | Clé unique par appareil : un vol ne compromet qu'une sonde. Port SWD verrouillé (point 2 d, j).                                                                                                                                                 |
| 6 | Un firmware malveillant est poussé par la mise à jour radio                            | faible  | élevé  | réduire                   | Image signée par le fabricant, vérifiée par MCUboot avant installation ; retour à une version antérieure interdit (point 2 c, f).                                                                                                               |
| 7 | Une vulnérabilité connue touche une dépendance (RTOS, pile LoRaWAN)                    | élevée  | élevé  | réduire                   | SBOM à chaque version, surveillance continue ; correctif publié sans délai, séparé des évolutions fonctionnelles (partie II, points 1 et 2).                                                                                                    |
| 8 | Le serveur de la collectivité est compromis et affiche de fausses valeurs              | moyenne | élevé  | hors périmètre, documenté | Hors du produit. La notice recommande un accès authentifié à deux facteurs et des alertes envoyées par un second canal.                                                                                                                         |

#### 4. Annexe I, partie I, point 2

| Point                                             | Applicable ?      | Mise en œuvre, ou justification                                                                                                         |
|---------------------------------------------------|-------------------|-----------------------------------------------------------------------------------------------------------------------------------------|
| a) Pas de vulnérabilité exploitable connue        | Oui               | Analyse du SBOM avant chaque version ; aucune vulnérabilité exploitable connue n'est livrée.                                            |
| b) Sécurisé par défaut, retour à l'état d'origine | Oui               | Aucun secret partagé par défaut ; seuils d'usine prudents. Un bouton interne rétablit la configuration d'usine, et la sonde le signale. |
| c) Mises à jour de sécurité                       | Oui               | Mises à jour radio signées, installées automatiquement par défaut ; l'exploitant peut les différer.                                     |
| d) Protection contre l'accès non autorisé         | Oui               | Pas d'interface locale ; SWD verrouillé ; seules les commandes authentifiées sont acceptées ; ouverture du capot signalée.              |
| e) Confidentialité                                | Oui, enjeu faible | Charge utile chiffrée par LoRaWAN ; aucune donnée personnelle.                                                                          |

| Point                                       | Applicable ?     | Mise en œuvre, ou justification                                                                                                                                                                                                                 |
|---------------------------------------------|------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| f) Intégrité                                | Oui, enjeu élevé | Trames authentifiées, compteurs de trames, activation OTAA ; firmware signé ; seuils bornés.                                                                                                                                                    |
| g) Minimisation des données                 | Oui              | Seules les grandeurs utiles à la surveillance sont transmises.                                                                                                                                                                                  |
| h) Disponibilité des fonctions essentielles | Oui, enjeu élevé | Les seuils sont évalués dans la sonde, sans attendre de commande ; message de vie horaire ; chien de garde ; alerte de pile basse.                                                                                                              |
| i) Pas d'impact sur les autres réseaux      | Oui              | Respect du rapport cyclique radio ; tentatives de connexion espacées, avec une part d'aléa.                                                                                                                                                     |
| j) Surface d'attaque limitée                | Oui              | Une seule interface externe, la radio ; SWD verrouillé.                                                                                                                                                                                         |
| k) Limitation de l'exploitation             | Oui              | Durcissement du compilateur et du RTOS (canaris de pile, protection mémoire MPU).                                                                                                                                                               |
| l) Journalisation et surveillance           | Oui              | Changements de seuils, ouvertures du capot, redémarrages et mises à jour sont envoyés à la plateforme. La désactivation existe, comme le texte le demande ; elle est elle-même signalée, et la notice la déconseille pour une réserve incendie. |
| m) Effacement des données et réglages       | Oui              | Le retour usine efface la session, les seuils, la configuration et l'historique local. La clé racine est conservée : c'est l'identité de l'appareil, pas une donnée de l'utilisateur.                                                           |

## 5. Annexe I, partie I, point 1, et partie II

- **Niveau de cybersécurité visé : élevé.** Une réserve incendie vide qui paraît pleine met en jeu la sécurité des personnes, que l'article 13, paragraphe 2, demande de prendre en compte. L'intégrité et la disponibilité des alertes priment.
- **Gestion des vulnérabilités :** SBOM CycloneDX à chaque version, surveillance continue des dépendances, adresse de contact publiée avec une politique de divulgation, correctifs livrés sans délai par mise à jour radio, avis de sécurité publiés.

## 6. Historique

| Date       | Version | Changement           |
|------------|---------|----------------------|
| 2026-10-06 | 1.0     | Première évaluation. |